

Azure Compliance Implementation Checklist

Document:	sample_azure_compliance_document.txt
Frameworks:	GDPR
Total Items:	5
Generated:	2025-11-24 20:21:59 UTC

Item #1: Implement Data Protection Impact Assessment (DPIA) Process

Priority:

CRITICAL

 Effort:

Complex

Description:

Establish a documented process for conducting DPIAs for all high-risk processing activities. This includes identifying processing activities, assessing risks, and implementing mitigation measures. This is a CRITICAL requirement under GDPR Article 35.

Gap Addressed: Lack of documented Data Protection Impact Assessments (DPIAs) as required by GDPR Article 35 for high-risk processing activities.

Azure Portal Navigation: Azure Portal > All services > Search for 'Privacy' or 'Purview'

Settings to Configure:

Setting Name:	DPIA Process Documentation
Current Value:	None
Required Value:	Documented DPIA process, including templates and procedures.
Location:	Document repository (e.g., Azure DevOps, SharePoint)

Step-by-Step Implementation Guide:

Step 1: Navigate to Azure Portal and search for 'Privacy' or 'Purview'

In the Azure Portal search bar, type 'Privacy' or 'Purview' and select the relevant service.
What to look for: You should see the Azure Privacy or Purview overview page.

Step 2: Create a DPIA Template

Develop a DPIA template that includes sections for describing the processing activity, identifying risks, assessing the severity and likelihood of risks, and documenting mitigation measures. Consider using the ICO's DPIA template as a starting point.
What to look for: A structured document template with sections for each DPIA requirement.

Step 3: Document DPIA Procedures

Create a documented procedure for conducting DPIAs, including roles and responsibilities, timelines, and approval processes. Store this documentation in a central, accessible location (e.g., Azure DevOps

Wiki, SharePoint).

What to look for: A written procedure outlining the steps for conducting a DPIA.

Step 4: Identify High-Risk Processing Activities

Review all data processing activities within Azure and identify those that are likely to result in a high risk to the rights and freedoms of natural persons. Examples include processing special categories of data, systematic monitoring, and large-scale processing.

What to look for: A list of processing activities that require a DPIA.

Step 5: Conduct DPIAs for Identified Activities

For each high-risk processing activity, complete the DPIA template, assess risks, and document mitigation measures. Ensure that the DPIA is reviewed and approved by relevant stakeholders.

What to look for: Completed DPIA documents for each high-risk processing activity.

Verification Steps:

- Step 1: Review the documented DPIA process to ensure it covers all required elements.
- Step 2: Verify that DPIAs have been conducted for all identified high-risk processing activities.
- Step 3: Confirm that DPIAs are regularly reviewed and updated.

Azure Services Required: Azure Privacy, Azure Purview

Expected Outcome: Compliance with GDPR Article 35, demonstrating a proactive approach to data protection.

Framework Reference: GDPR Article 35

Additional Notes: Consider using a DPIA tool to streamline the process. Ensure that DPIAs are conducted before implementing new processing activities.

Item #2: Designate a Data Protection Officer (DPO) or Document Justification for Not Needing One

Priority:

CRITICAL

Effort:

Moderate

Description:

Determine whether a DPO is required based on GDPR Articles 37-39. If required, designate a DPO and provide them with the necessary resources and authority. If not required, document the justification for not designating a DPO.

Gap Addressed: Absence of a designated Data Protection Officer (DPO) or justification for not needing one, as per GDPR Articles 37-39.

Azure Portal Navigation: N/A - Documentation and organizational structure

Settings to Configure:

Setting Name:	DPO Designation
Current Value:	None
Required Value:	Designated DPO or documented justification for not needing one.
Location:	Organizational chart and documentation repository

Step-by-Step Implementation Guide:

Step 1: Assess the Need for a DPO

Evaluate whether the organization's core activities involve regular and systematic monitoring of data subjects on a large scale or processing of special categories of data. Refer to GDPR Articles 37-39 for specific criteria.

What to look for: A clear determination of whether a DPO is required based on GDPR criteria.

Step 2: Designate a DPO (If Required)

If a DPO is required, appoint a qualified individual with the necessary expertise and resources. Document the DPO's responsibilities, authority, and reporting structure.

What to look for: A formal appointment letter or job description for the DPO.

Step 3: Document Justification for Not Needing a DPO (If Not Required)

If a DPO is not required, document the reasons why, based on the GDPR criteria. This documentation should be reviewed and approved by senior management.

What to look for: A written justification for not designating a DPO, signed by senior management.

Step 4: Communicate DPO Information

If a DPO is appointed, communicate their contact information to data subjects and relevant authorities.

What to look for: Published contact information for the DPO (e.g., on the organization's website).

Verification Steps:

- Step 1: Review the assessment of the need for a DPO to ensure it is accurate and complete.
- Step 2: Verify that a DPO has been designated (if required) and provided with the necessary resources.
- Step 3: Confirm that the justification for not needing a DPO (if applicable) is documented and approved.

Azure Services Required: None

Expected Outcome: Compliance with GDPR Articles 37-39, demonstrating a clear understanding of DPO requirements.

Framework Reference: GDPR Articles 37-39

Additional Notes: Even if a DPO is not legally required, consider appointing a privacy officer to oversee data protection activities.

Item #3: Document Lawful Basis for Processing Personal Data

Priority:

CRITICAL

Effort:

Moderate

Description:

For each specific processing activity, identify and document the lawful basis for processing personal data, as required by GDPR Article 6. This could be consent, contract, legal obligation, vital interests, public task, or legitimate interests.

Gap Addressed: Insufficient detail on the lawful basis for processing personal data for each specific processing activity, as required by GDPR Article 6. The document mentions GDPR compliance but doesn't specify the lawful basis used (e.g., consent, contract, legal obligation).

Azure Portal Navigation: N/A - Documentation and data flow diagrams

Settings to Configure:

Setting Name:	Lawful Basis Documentation
Current Value:	Not specified for each processing activity
Required Value:	Documented lawful basis for each processing activity.
Location:	Data processing inventory and documentation repository

Step-by-Step Implementation Guide:

Step 1: Create a Data Processing Inventory

Develop a comprehensive inventory of all data processing activities within Azure, including the types of personal data processed, the purposes of processing, and the data subjects involved.

What to look for: A detailed list of all data processing activities.

Step 2: Identify Lawful Basis for Each Activity

For each processing activity, determine the appropriate lawful basis for processing personal data. Consider the specific circumstances of each activity and consult with legal counsel if necessary.

What to look for: A documented lawful basis (e.g., consent, contract, legal obligation) for each processing activity.

Step 3: Document Lawful Basis

Document the lawful basis for each processing activity in the data processing inventory. Include a clear explanation of why that lawful basis is appropriate.

What to look for: A clear and concise explanation of the lawful basis for each processing activity in the data processing inventory.

Step 4: Implement Consent Mechanisms (If Applicable)

If consent is used as the lawful basis, implement mechanisms for obtaining and managing consent, including providing clear and concise information to data subjects and allowing them to withdraw their consent easily.

What to look for: Consent forms, consent management platforms, and procedures for withdrawing consent.

Verification Steps:

- Step 1: Review the data processing inventory to ensure it is complete and accurate.
- Step 2: Verify that a lawful basis has been identified and documented for each processing activity.
- Step 3: Confirm that consent mechanisms (if applicable) are implemented and functioning correctly.

Azure Services Required: Azure Active Directory, Azure Data Lake Storage, Azure SQL Database

Expected Outcome: Compliance with GDPR Article 6, demonstrating a legal basis for all data processing activities.

Framework Reference: GDPR Article 6

Additional Notes: Regularly review the lawful basis for processing to ensure it remains appropriate. Document any changes to the lawful basis.

Item #4: Implement Mechanisms for Data Subject Rights

Priority:

HIGH

Effort:

Complex

Description:

Establish clear processes for facilitating and managing data subject rights (access, rectification, erasure, restriction, portability, objection) as required by GDPR Articles 15-22. Provide specific instructions and forms for data subjects to exercise their rights.

Gap Addressed: Limited information on how data subject rights (access, rectification, erasure, restriction, portability, objection) are facilitated and managed in practice, beyond stating that procedures are documented per GDPR Articles 15-22. Specific processes for handling requests are not detailed.

Azure Portal Navigation: N/A - Documentation and workflow implementation

Settings to Configure:

Setting Name:	Data Subject Rights Procedures
Current Value:	General documentation only
Required Value:	Detailed procedures and forms for each data subject right.
Location:	Documentation repository and data subject rights portal

Step-by-Step Implementation Guide:

Step 1: Create a Data Subject Rights Portal

Develop a portal or webpage where data subjects can submit requests to exercise their rights. This portal should provide clear instructions and forms for each type of request.

What to look for: A user-friendly portal with clear instructions and forms for data subject rights requests.

Step 2: Develop Procedures for Each Right

Create detailed procedures for handling each type of data subject rights request, including access, rectification, erasure, restriction, portability, and objection. These procedures should specify the steps involved, the roles and responsibilities of personnel, and the timelines for responding to requests.

What to look for: Documented procedures for each data subject right, including timelines and responsibilities.

Step 3: Implement Automated Workflows (Optional)

Consider implementing automated workflows using Azure Logic Apps or Azure Functions to streamline the processing of data subject rights requests. This can help to improve efficiency and reduce the risk of errors.

What to look for: Automated workflows for processing data subject rights requests.

Step 4: Train Personnel

Train personnel on the procedures for handling data subject rights requests. Ensure that they understand their responsibilities and are able to respond to requests in a timely and accurate manner.

What to look for: Training records for personnel involved in handling data subject rights requests.

Verification Steps:

- Step 1: Test the data subject rights portal to ensure it is functioning correctly.
- Step 2: Review the procedures for handling data subject rights requests to ensure they are complete and accurate.

- Step 3: Verify that personnel are trained on the procedures for handling data subject rights requests.

Azure Services Required: Azure Active Directory, Azure Logic Apps, Azure Functions

Expected Outcome: Compliance with GDPR Articles 15-22, demonstrating a commitment to data subject rights.

Framework Reference: GDPR Articles 15-22

Additional Notes: Ensure that data subjects are informed of their rights and how to exercise them. Provide clear and concise information in a language they understand.

Item #5: Implement Mechanisms for International Data Transfers

Priority:

HIGH

Effort:

Complex

Description:

Establish mechanisms for international data transfers and ensure adequate protection when transferring data outside the EU, as required by GDPR Chapter V. This may involve using Standard Contractual Clauses (SCCs), Binding Corporate Rules (BCRs), or other approved transfer mechanisms.

Gap Addressed: No explicit mention of mechanisms for international data transfers and ensuring adequate protection when transferring data outside the EU, as required by GDPR Chapter V.

Azure Portal Navigation: N/A - Documentation and contractual agreements

Settings to Configure:

Setting Name:	International Data Transfer Mechanisms
Current Value:	None specified
Required Value:	Documented mechanisms for international data transfers (e.g., SCCs, BCRs).
Location:	Legal agreements and data transfer documentation

Step-by-Step Implementation Guide:

Step 1: Identify International Data Transfers

Identify all data transfers that involve transferring personal data outside the European Economic Area (EEA).

What to look for: A list of all international data transfers.

Step 2: Implement Appropriate Transfer Mechanisms

For each international data transfer, implement an appropriate transfer mechanism, such as Standard Contractual Clauses (SCCs), Binding Corporate Rules (BCRs), or other approved mechanisms. Ensure that the transfer mechanism provides adequate protection for the personal data being transferred.

What to look for: Signed SCCs, approved BCRs, or other documentation demonstrating compliance with GDPR Chapter V.

Step 3: Conduct Transfer Impact Assessments (TIAs)

Conduct Transfer Impact Assessments (TIAs) to assess the level of protection afforded to personal data in the recipient country and to identify any supplementary measures that may be necessary to ensure adequate protection.

What to look for: Completed TIAs for each international data transfer.

Step 4: Implement Supplementary Measures (If Necessary)

If the TIA identifies any risks to the protection of personal data, implement supplementary measures to mitigate those risks. This may include encryption, pseudonymization, or other technical and organizational measures.

What to look for: Documentation of supplementary measures implemented to protect personal data during international transfers.

Verification Steps:

- Step 1: Review the list of international data transfers to ensure it is complete and accurate.
- Step 2: Verify that appropriate transfer mechanisms are in place for each international data transfer.

- Step 3: Confirm that TIAs have been conducted and that supplementary measures have been implemented (if necessary).

Azure Services Required: Azure Policy, Azure Key Vault

Expected Outcome: Compliance with GDPR Chapter V, ensuring adequate protection for personal data transferred outside the EU.

Framework Reference: GDPR Chapter V

Additional Notes: Stay up-to-date on the latest guidance from the European Data Protection Board (EDPB) on international data transfers.